

DOCUMENTAÇÃO TÉCNICA

Sistema Lucas

Plataforma de Prontuário Eletrônico e Gestão Clínica

Manual Técnico — Arquitetura, Funcionalidades e Conformidade LGPD

Público-alvo	Equipe técnica, desenvolvedores e administradores de TI
Versão do documento	1.0
Data de emissão	21 de maio de 2026
Stack	Spring Boot 3.4 · Angular 21 · PostgreSQL 15 · Docker
Classificação	Documento interno

Sumário

1. Visão Geral do Sistema
2. Arquitetura Técnica
3. Modelo de Dados e Migrações
4. Perfis de Acesso e Controle de Permissões
5. Módulos Funcionais
6. Máquina de Estados de Consultas
7. Rotinas Automatizadas
8. Segurança da Informação
9. Conformidade LGPD — Implementação Técnica
10. Infraestrutura, Deploy e Continuidade
11. Qualidade e Testes

1. Visão Geral do Sistema

O **Sistema Lucas** é uma plataforma full-stack de gestão clínica e prontuário eletrônico, desenvolvida para um instituto de atendimento à saúde sem fins lucrativos. O sistema concentra três grandes domínios funcionais: o **agendamento de consultas**, a **gestão de prontuários e documentos clínicos** e a **administração de usuários e agendas**.

Por tratar dados pessoais sensíveis de saúde (Art. 5º, II da LGPD), o sistema foi arquitetado com forte ênfase em conformidade legal: criptografia em repouso, trilha de auditoria, controle de acesso por perfil, registro demonstrável de consentimento e anonimização irreversível compatível com a retenção legal de prontuários.

1.1 Características principais

Domínio	Descrição
Arquitetura	Monólito modular containerizado (backend, frontend e banco em contêineres separados)
Comunicação	API REST stateless com autenticação JWT
Persistência	PostgreSQL 15 com versionamento de schema via Flyway
Reatividade frontend	Angular 21 com componentes standalone e Signals
Notificações	E-mails transacionais e lembretes agendados via SMTP
Conformidade	LGPD — Lei nº 13.709/2018 (dados sensíveis de saúde)

2. Arquitetura Técnica

2.1 Pilha tecnológica

Camada	Tecnologia	Versão
Frontend	Angular (standalone components, Signals)	21
Backend	Spring Boot / Java	3.4 / Java 21
Banco de dados	PostgreSQL	15
Servidor web / proxy	nginx (serve o frontend e termina TLS)	—
Orquestração	Docker Compose	—
Migrações de schema	Flyway	—

2.2 Arquitetura em camadas (backend)

O backend segue uma arquitetura estritamente em camadas:

Controller → Service → Repository → Entity

Camada	Pacote	Responsabilidade
Controller	<code>controller/</code>	Endpoints REST; nunca expõem entidades JPA diretamente — sempre DTOs
Service	<code>service/</code>	Regras de negócio; cada método público é uma fronteira transacional
Repository	<code>repository/</code>	Interfaces Spring Data JPA de acesso a dados
Model	<code>model/</code>	Entidades JPA, DTOs (Java Records) e enums
Security	<code>security/</code>	Filtro JWT, rate limiting, tratamento global de exceções
Config	<code>config/</code>	Inicializadores, conversores JPA, runners de migração

2.3 Estrutura do frontend

O frontend é organizado em componentes standalone do Angular 21, um por página, cada qual com seu arquivo `.ts`, `.html` e geralmente um `.service.ts` dedicado. O módulo de segurança (`app/security/`) concentra o serviço de autenticação, o guard de rotas e o interceptor HTTP, que injeta o token JWT em todas as requisições. O serviço de inatividade (`inactivity.service.ts`) encerra automaticamente sessões ociosas.

3. Modelo de Dados e Migrações

3.1 Entidades principais

Entidade	Descrição
<code>User</code>	Usuário base do sistema; armazena credenciais (hash Argon2id) e papel
<code>Patient</code>	Paciente — herda de User; dados cadastrais e de saúde
<code>Professional</code>	Profissional de saúde — herda de User; registro de conselho, especialidade e modalidade de atendimento
<code>Appointment</code>	Consulta agendada; carrega o estado da máquina de estados
<code>ProfessionalAvailability</code>	Janelas de disponibilidade da agenda do profissional
<code>Prontuario</code>	Registro clínico — notas de atendimento (criptografadas)
<code>Documento</code>	Documentos clínicos (laudos, receitas, exames) em conteúdo criptografado
<code>AuditLog</code>	Trilha de auditoria de acesso a dados sensíveis
<code>RefreshToken</code> / <code>TokenDenylist</code>	Renovação rotativa de sessão e revogação de tokens
<code>VerificationToken</code> / <code>PasswordResetToken</code>	Tokens de uso único para verificação de e-mail e redefinição de senha

3.2 Histórico de migrações Flyway

O schema é versionado por Flyway; as migrações executam automaticamente na inicialização. **Migrações existentes nunca são alteradas** — toda mudança gera um novo arquivo `V{n}__descrição.sql`.

Versão	Mudança
V1	Baseline do schema
V2	Verificação de e-mail
V3	Constraint UNIQUE em consultas (anti-corrida)
V4	Rastreamento de faltas/penalidades do paciente
V5	Unicidade de CPF via <code>cpf_hash</code>
V6	Flag de paciente ativo
V7 / V8	Aceite dos termos e rastreamento de consentimento
V9	Correção da disponibilidade do profissional
V10	Colunas de MFA (<code>mfa_enabled</code> , <code>totp_secret</code>)
V11	Refresh tokens e denylist de revogação
V12	Modalidade de atendimento do profissional

4. Perfis de Acesso e Controle de Permissões

O controle de acesso baseado em papéis (RBAC) é aplicado via `@EnableMethodSecurity` e do papel codificado no JWT. São três perfis:

Perfil	Permissões
ADMIN	Gestão completa de usuários e profissionais; leitura da trilha de auditoria; exportações administrativas
PROFESSIONAL	Gestão da própria agenda e disponibilidade; prontuários e documentos dos próprios atendimentos
PATIENT	Visualização e confirmação das próprias consultas; acesso aos próprios documentos liberados

Princípio do menor privilégio: cada endpoint exige o papel mínimo necessário, validado por anotações `@PreAuthorize`. Toda ação sensível é registrada na trilha de auditoria.

5. Módulos Funcionais

5.1 Autenticação e gestão de conta

- **Cadastro** com aceite versionado dos Termos de Uso e Política de Privacidade;
- **Verificação de e-mail** — contas iniciam como não verificadas; token de validade de 24h enviado por SMTP;
- **Login** com emissão de JWT; **refresh token rotativo** de uso único;
- **Recuperação de senha** via token de uso único e curta validade;
- **Logout efetivo** com revogação do token via `denylist`;
- **Encerramento de sessão por inatividade** no frontend.

5.2 Agendamento de consultas

- Consulta de profissionais disponíveis, com filtro por **modalidade de atendimento** (presencial, online ou híbrido);
- Consulta de horários livres (*slots*) e dias de trabalho do profissional;
- Agendamento com proteção contra concorrência via constraint UNIQUE (`professional_id, date_time`);
- Confirmação em duas etapas (profissional e, depois, paciente);
- Reagendamento e cancelamento com justificativa;
- Controle de faltas (*no-show*) com penalidades e bloqueio temporário.

5.3 Prontuários e documentos clínicos

- Registro de notas clínicas pelo profissional responsável pelo atendimento;
- Upload e gestão de documentos clínicos (laudos, receitas, exames);
- Conteúdo de prontuários e documentos **criptografado em repouso**;
- Todo acesso a dados sensíveis é registrado na trilha de auditoria.

5.4 Gestão de agenda do profissional

- Cadastro das janelas de disponibilidade por data;
- Visão da agenda diária e das próximas consultas;
- Notificação de prazo para submissão da agenda do mês seguinte.

5.5 Painel administrativo e dashboard

- Dashboard com indicadores por perfil (consultas do dia, pendências de confirmação);
- Gestão de usuários, pacientes e profissionais;
- Aprovação, recusa e desbloqueio de contas.

5.6 Exportação e portabilidade de dados

- Exportação dos dados do titular em formato estruturado, atendendo ao direito de portabilidade (Art. 18, V da LGPD).

6. Máquina de Estados de Consultas

O ciclo de vida de uma consulta é governado por uma máquina de estados explícita:

AGENDADA → **CONFIRMADA_PROFISSIONAL** → **CONFIRMADA** → **CONCLUIDA / CANCELADA / FALTA**

- **AGENDADA** — consulta criada, aguardando o profissional;
- **CONFIRMADA_PROFISSIONAL** — o profissional confirmou; aguarda o paciente;
- **CONFIRMADA** — ambas as partes confirmaram;
- **CONCLUIDA** — atendimento realizado;
- **CANCELADA** — cancelada por qualquer das partes, com justificativa;
- **FALTA** — paciente não compareceu; impacta o controle de penalidades.

A constraint UNIQUE em `(professional_id, date_time)` impede, no nível do banco, que duas consultas ocupem o mesmo horário — eliminando condições de corrida sob requisições concorrentes.

7. Rotinas Automatizadas

Tarefas agendadas (`@Scheduled` , fuso `America/Sao_Paulo`) executam processos recorrentes:

Rotina	Periodicidade	Função
Lembretes de consulta	Diária — 10h	Envia e-mail de lembrete das consultas do dia seguinte
Prazo de agenda	Diária — 8h	Alerta o profissional sobre o prazo de submissão da agenda do mês seguinte
Consultas atrasadas	Diária — 8h05	Alerta o profissional sobre consultas com data passada e status pendente
Pendências semanais	Segunda — 9h	Notifica profissionais e pacientes sobre confirmações pendentes
Limpeza de dados	Periódica	Expurgo de tokens expirados, atendendo ao princípio do prazo determinado

8. Segurança da Informação

8.1 Controles implementados

Controle	Implementação
Autenticação	JWT (HMAC-SHA256), validado pelo <code>SecurityFilter</code> em cada requisição
Armazenamento do token	Cookie <code>HttpOnly</code> + <code>Secure</code> + <code>SameSite</code> — mitiga roubo via XSS
Renovação de sessão	Refresh token rotativo de uso único; <code>denylist</code> de revogação para logout efetivo
Senhas	Hash <code>Argon2id</code> (recomendado pelo OWASP)
Dados em repouso	AES-256-GCM via <code>EncryptionConverter</code> aplicado por <code>@Convert</code>
Identificação por CPF	<code>cpf_hash</code> via HMAC-SHA256 com <i>pepper</i> dedicado, fora do banco
Rate limiting	Bucket4j — proteção contra força bruta nos endpoints de autenticação
Trilha de auditoria	<code>AuditLogService</code> registra todo acesso a dados sensíveis
Verificação de e-mail	Token de uso único com validade de 24h
Timeout de sessão	Encerramento automático por inatividade no frontend
CORS	Restrito a origens explicitamente autorizadas (<code>ALLOWED_ORIGINS</code>)
Gestão de segredos	Docker Secrets — segredos fora do <code>.env</code> e fora do versionamento

8.2 Gestão de chaves criptográficas

O `EncryptionConverter` opera com suporte multi-chave: uma **chave primária AES-256** usada para cifrar e uma lista de **chaves legadas** usada apenas para decifrar dados anteriores a uma rotação. Isso permite a **rotação de chave sem indisponibilidade**: o `EncryptionMigrationRunner` recifra a base para a chave forte em lote, sob controle explícito da flag `app.migration.crypto.enabled`.

Boa prática: os runners de migração criptográfica são desabilitados por padrão e só executam quando a flag é explicitamente ativada, evitando reprocessamento custoso a cada inicialização.

9. Conformidade LGPD — Implementação Técnica

O sistema passou por auditoria de conformidade LGPD sob a ótica de Encarregado de Proteção de Dados. Todas as não conformidades identificadas foram tratadas. Os controles técnicos abaixo materializam a conformidade.

Requisito LGPD	Implementação técnica	Status
Segurança de dados (Art. 46)	Criptografia AES-256-GCM em repouso para todos os dados sensíveis	OK
Integridade da cifra	<code>EncryptionConverter</code> trata falha de decifragem como erro auditável — sem <i>fallback</i> de texto plano	OK
Identificação inequívoca	<code>cpf_hash</code> via HMAC-SHA256 com <i>pepper</i> — resistente a força bruta	OK
Gestão de segredos	Segredos migrados para Docker Secrets; <code>.env</code> contém apenas configuração não sensível	OK
Base legal do prontuário	Dados de saúde fundamentados na tutela da saúde (Art. 11, II, "a"), dissociados do consentimento	OK
Portabilidade (Art. 18, V)	Exportação completa dos dados do titular em formato estruturado	OK
Prazo determinado (Art. 15)	<code>DataCleanupTask</code> — expurgo automático de tokens e dados expirados	OK
Transferência internacional (Art. 33)	Envio de e-mails via Google LLC (EUA) declarado na Política de Privacidade	OK
Canal do titular (Art. 41)	Canal de contato de proteção de dados publicado na Política de Privacidade	OK
Trilha de auditoria (Art. 11, II, "g")	<code>AuditLogService</code> registra todo acesso a dados de saúde	OK
Resposta a incidentes (Art. 48)	Plano documentado de resposta a incidentes e comunicação à ANPD	OK
Direito ao esquecimento (Art. 18, VI)	Exclusão física ou anonimização irreversível, preservando o prontuário de guarda obrigatória	OK

9.1 Anonimização versus retenção legal

O prontuário clínico tem guarda obrigatória de **20 anos** (Lei nº 13.787/2018 e Resolução CFM nº 1.821/2007). O sistema concilia esse dever com o direito ao esquecimento por meio de um modelo híbrido: ao solicitar o encerramento da conta, os **dados de identificação são anonimizados de forma irreversível**, enquanto o registro clínico — desvinculado da identidade — é preservado pelo prazo legal.

9.2 Registro de consentimento

O aceite dos Termos é registrado de forma demonstrável (Art. 8º, §1º): data, hora e **versão** do documento aceite são persistidos. O consentimento cobre a criação da conta e as comunicações operacionais; o tratamento dos dados de saúde independe dele.

9.3 Designação de Encarregado (DPO)

Por se tratar de instituição sem fins lucrativos de pequeno porte, a indicação formal de Encarregado é facultativa nos termos da **Resolução CD/ANPD nº 2/2022**. O canal oficial de contato para o exercício de direitos é publicado na Política de Privacidade e é suficiente para o atendimento aos titulares.

10. Infraestrutura, Deploy e Continuidade

10.1 Orquestração

Três contêineres compõem o sistema, orquestrados por Docker Compose: o banco PostgreSQL (com volume nomeado persistente), o backend Spring Boot e o frontend Angular servido por nginx. Segredos são montados via Docker Secrets em `/run/secrets/`.

10.2 Ambientes

Ambiente	Perfil Spring	Característica
Desenvolvimento	<code>dev</code>	Popula dados fictícios via <code>DataInitializer</code>
Produção	<code>prod</code>	Banco limpo; configuração endurecida

10.3 Processo de deploy

- `deploy-dev.sh` — sobe o ambiente local com dados de teste;
- `deploy-prod.sh` — sobe o ambiente de produção;
- `push-and-deploy.sh` — sincroniza (rsync) e implanta no servidor remoto via SSH.

Os volumes nomeados do Docker preservam todos os dados entre *deploys*. As migrações Flyway são incrementais e não destrutivas (`ADD COLUMN IF NOT EXISTS`), garantindo atualizações seguras.

10.4 Backup

O script `backup.sh` realiza a cópia de segurança do banco de dados. Recomenda-se a verificação periódica da integridade das cópias e o armazenamento redundante fora do servidor de produção.

11. Qualidade e Testes

A garantia da integridade operacional do sistema baseia-se em uma estratégia contínua de testes em múltiplas camadas. Um roadmap completo e em expansão (focado em atingir ~435 cenários de teste) orienta o time de engenharia.

- **Testes End-to-End (Cypress):** Validam os fluxos críticos na perspectiva do usuário, como autenticação programática, penalidades por faltas, gestão de agendas (disponibilidade) e alertas do dashboard.
- **Testes Unitários de Frontend (Vitest):** Garantem o isolamento da lógica dos componentes e serviços Angular, como tratamento de estado, signals e navegação.
- **Testes Unitários e de Integração (JUnit + Mockito):** Focam em regras de negócio críticas (LGPD, anonimização, criptografia AES, agendamento concorrente e IDOR) e na camada REST via [@WebMvcTest](#).

A cobertura exhaustiva de testes mitiga riscos de regressão durante refatorações, protegendo as lógicas de isolamento de dados do paciente e as chaves de proteção criptográfica.